COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Considerations

Mestre CyberSec · **Aula 5.1 — Security Considerations** (4:51) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Regulatório: GDPR (UE), HIPAA (saúde), PCI-DSS (cartão), SOX (financeiro), FERPA (escola); Padrões Industriais: CIS Benchmarks, Família ISO (27001 ISMS, 27002 controles, 31000 ERM) e Família NIST: CSF (infraestrutura crítica), SP 800-53 (catálogo controles), SP 800-37 (RMF) e SP 800-30 (risco).

💡 Highlights que a prova CompTIA cobra

- NIST CSF = infraestrutura crítica (Identify, Protect, Detect, Respond, Recover); SP 800-53 = catálogo de controles
- ISO 27001 = requisitos do SGSI/ISMS; ISO 27002 = código de práticas e controles de segurança
- Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro, GDPR cidadãos da UE

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'framework for improving critical infrastructure cybersecurity'=NIST CSF
- 'standard specifically addressing an ISMS'=ISO 27001 / ISO 27002
- 'catalog of security and privacy controls for federal systems'=NIST SP 800-53

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Considerations)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Regulamento Geral de Proteção de Dados (GDPR)
Regulamento da UE que protege dados pessoais de cidadãos/residentes da UE e se aplica a organizações em qualquer lugar que processem esses dados.

⚠️ ***Armadilha CompTIA:*** *Questão citando 'dados de cidadãos da UE independente da localização da empresa' = GDPR.*

• Lei de Portabilidade e Responsabilidade de Seguros de Saúde (HIPAA)
Lei dos EUA que protege informações de saúde (PHI) e exige salvaguardas de privacidade e segurança na área de saúde.

⚠️ ***Armadilha CompTIA:*** *Saúde, PHI, hospital ou seguradora nos EUA = HIPAA.*

• Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)
Padrão da indústria para organizações que armazenam, processam ou transmitem dados de titulares de cartão, com requisitos para proteger dados de cartões.

⚠️ ***Armadilha CompTIA:*** *Dados de cartão de crédito/débito = PCI-DSS; é padrão da indústria, não lei governamental.*

• Lei Sarbanes-Oxley (SOX)
Lei dos EUA que impõe requisitos de relatórios financeiros, controles internos e retenção de registros a empresas de capital aberto.

⚠️ ***Armadilha CompTIA:*** *Empresa de capital aberto, relatórios financeiros ou controles internos = SOX.*

• Lei de Direitos e Privacidade Educacionais da Família (FERPA)
Lei dos EUA que protege a privacidade de registros educacionais de estudantes em instituições que recebem financiamento federal.

⚠️ ***Armadilha CompTIA:*** *Registros acadêmicos, escola/universidade ou aluno = FERPA.*

• Centro para Segurança na Internet (CIS)

Organização que publica os Controles e Benchmarks CIS, boas práticas priorizadas de segurança para endurecer sistemas e reduzir risco cibernético.

⚠ ***Armadilha CompTIA:*** *Controles priorizados, benchmarks de configuração ou hardening = CIS.*

• NIST Cybersecurity Framework (CSF) (NIST CSF)

Framework voluntário criado para aprimorar a cibersegurança de infraestruturas críticas e gerenciar riscos corporativos através de cinco funções centrais: Identify, Protect, Detect, Respond e Recover (+ Govern).

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'improving critical infrastructure cybersecurity' ou 'common framework integrating standards' = NIST CSF.*

• NIST SP 800-53 (Catálogo de Controles de Segurança e Privacidade)

Catálogo exaustivo de controles de segurança e privacidade para sistemas e agências federais dos EUA, servindo de base para conformidade FISMA e benchmarks.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'comprehensive catalog of security and privacy controls for federal systems' = NIST SP 800-53.*

• NIST SP 800-37 (Risk Management Framework - RMF)

Diretrizes para aplicação do RMF em sistemas governamentais, fornecendo um ciclo de vida estruturado em etapas (Categorizar, Selecionar, Implementar, Avaliar, Autorizar, Monitorar) para homologação de sistemas.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'Risk Management Framework' ou 'disciplined process for system authorization and monitoring' = NIST SP 800-37 (RMF).*

• NIST SP 800-30 (Condução de Avaliações de Risco)

Publicação especial com orientações práticas para a condução formal de avaliações de risco, estimando fontes de ameaças, vulnerabilidades, probabilidade e impacto.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'guidance for conducting risk assessments' = NIST SP 800-30. Não confundir com CSF ou 800-53.*

• ISO/IEC 27001 (Requisitos para SGSI / ISMS) (ISO 27001)

Padrão internacional que estabelece os requisitos formais e auditáveis para implementação, operação e certificação de um Sistema de Gestão de Segurança da Informação (SGSI / ISMS).

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'ISO standard specifically addressing an ISMS for formal certification' = ISO 27001.*

• ISO/IEC 27002 (Código de Práticas de Controles de Segurança) (ISO 27002)

Padrão complementar que fornece o código de práticas e orientações detalhadas de implementação para os controles de segurança de informação da ISO 27001.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'code of practice and implementation guidance for security controls' = ISO 27002.*

• ISO 27005 e ISO 31000 (Gestão de Riscos) (ISO 27005 / 31000)

A ISO 27005 orienta a gestão de riscos específicos de segurança da informação; a ISO 31000 abrange a gestão de riscos corporativos gerais (ERM) de toda a empresa.

⚠ ***Armadilha CompTIA:*** *Distinção CompTIA: ISO 27005 = risco em TI/segurança; ISO 31000 = risco corporativo global; ISO 9001 = qualidade de fabricação.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Fatores Regulatórios e Legais (Regulatory & Statutory Considerations)

🏠 **Analogia Intuitiva:** As regras de segurança impostas pelo corpo de bombeiros e pela vigilância sanitária em uma rede de farmácias: você não pode decidir desligar os extintores ou economizar na refrigeração de remédios porque isso custa caro. Se desrespeitar, sua licença de funcionamento é cassada e o alvará é cancelado imediatamente.

🔍 **Causa Raiz / Por que foi criado:** Empresas operam em jurisdições múltiplas e setores altamente regulados (saúde, financeiro, dados de menores) onde a negligência de segurança transborda para ilícitos civis e penais.

🛡️ **Visão do Auditor de GRC:** Mapear a matriz de obrigações regulatórias da empresa (ex: GDPR na Europa, HIPAA nos EUA, LGPD no Brasil, PCI-DSS para cartões) e cruzar com os controles de segurança implementados para garantir auditoria sem lacunas legais.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'laws, industry mandates, and statutory rules that dictate security architecture decisions regardless of internal preferences' = Regulatory & Compliance Considerations.

📌 Sistemas Legados e Fim de Vida Útil (End of Life - EOL / End of Support Life - EOSL)

🏠 **Analogia Intuitiva:** Um carro antigo com mais de 40 anos cuja fábrica fechou e não existem mais peças sobressalentes nem cintos modernos de três pontos à venda. Se a peça de freio quebrar, ninguém fabrica outra. Para mantê-lo rodando na via pública sem colocar terceiros em risco, você precisa de autorizações especiais e condução restrita em pistas fechadas.

🔍 **Causa Raiz / Por que foi criado:** Fabricantes de software e hardware encerram o suporte e o fornecimento de patches de segurança após um ciclo de vida planejado, deixando sistemas com vulnerabilidades perpétuas conhecidas por atacantes.

🛡️ **Visão do Auditor de GRC:** Manter inventário de ativos com rastreamento de datas de EOL/EOSL, exigir planos de migração formalizados e implementar isolamento severo de rede (air gap ou microsegmentação) para sistemas legados insubstituíveis.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'vendor no longer provides security updates, technical support, or bug fixes for an operating system' = End of Life (EOL) / End of Service Life (EOSL).

📌 Conflito entre Segurança e Usabilidade / Agilidade Operacional

🏠 **Analogia Intuitiva:** Colocar cinco fechaduras biométricas, três cadeados de segredo e uma porta giratória blindada na entrada de uma padaria de bairro. O comércio se torna o lugar mais seguro do mundo contra assaltos, mas nenhum cliente entra para comprar pão e os funcionários levam 40 minutos para entregar um café, falindo o negócio.

🔍 **Causa Raiz / Por que foi criado:** Controles de segurança excessivamente burocráticos ou lentos forçam os colaboradores a criar 'Shadow IT' (compartilhar arquivos por serviços externos não autorizados) para conseguir bater suas metas de trabalho.

🛡️ **Visão do Auditor de GRC:** Avaliar o impacto de cada novo controle de segurança na experiência do usuário, monitorar indicadores de Shadow IT e conduzir pesquisas de satisfação de usabilidade antes e depois de implantações críticas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'employees bypass complicated VPN authentication by sending confidential spreadsheets to personal Dropbox accounts' = Poor Usability leading to Shadow IT.

📌 A Família NIST: CSF vs SP 800-53 vs SP 800-37 vs SP 800-30

🏠 **Analogia Intuitiva:** A construção e vistoria de uma agência bancária ou delegacia blindada: 1) NIST CSF é a planta arquitetônica e o conceito executivo de alto nível (tem guarita, cofre, extintor e cerca); 2) NIST SP 800-53 é o catálogo de compras de materiais da ABNT/Inmetro (lista as especificações de cada parafuso de aço, calibre da fechadura e espessura do vidro); 3) NIST SP 800-37 (RMF) é o alvará de vistoria do Corpo de Bombeiros e o ciclo de homologação formal (as etapas burocráticas para autorizar o prédio a abrir as portas); 4) NIST SP 800-30 é a perícia técnica que calcula a probabilidade e o dano de um desastre (avaliação de riscos).

🔍 **Causa Raiz / Por que foi criado:** O NIST CSF nasceu da Executive Order 13636 ('Improving Critical Infrastructure Cybersecurity') para criar uma linguagem comum voluntária de gestão de riscos. Já as Publicações Especiais (SP 800) fornecem orientações técnicas detalhadas exigidas por lei (FISMA) para agências federais dos EUA.

🛡️ **Visão do Auditor de GRC:** O auditor avalia se a organização utiliza o NIST CSF para medir maturidade executiva ou se é obrigada contratualmente a comprovar a implementação de controles técnicos específicos catalogados no NIST SP 800-53.

⚠️ **Como cai na Prova CompTIA:** Gatilhos CompTIA cruciais: 'framework for improving critical infrastructure cybersecurity' ou 'common framework integrating industry standards' = NIST CSF. 'Catalog of security and privacy controls for federal systems' = NIST SP 800-53. 'Risk Management Framework / system authorization lifecycle' = NIST SP 800-37. 'Guidance for conducting risk assessments' = NIST SP 800-30.

📌 A Família de Normas ISO: 27001 vs 27002 vs 27005 vs 31000 vs 9001

🏠 **Analogia Intuitiva:** A habilitação de segurança de uma grande empresa: 1) ISO 27001 é o Diploma Oficial de Habilitação do SGSI/ISMS que vai na moldura da parede após passar na prova do auditor; 2) ISO 27002 é o Manual de Estudos e Código de Trânsito que detalha exatamente como instalar as trancas e firewalls; 3) ISO 27005 é a aula de direção defensiva e cálculo de perigo nas estradas de TI; 4) ISO 31000 é a gestão de crises da empresa inteira (processos trabalhistas, rombo financeiro e greves); 5) ISO 9001 é o controle de qualidade dos produtos na linha de montagem da fábrica.

🔍 **Causa Raiz / Por que foi criado:** Organizações internacionais exigem comprovação padronizada de governança de segurança. A ISO 27001 define os requisitos auditáveis para certificação de um SGSI (ISMS), enquanto a ISO 27002 fornece as diretrizes práticas para implementação desses controles.

🛡️ **Visão do Auditor de GRC:** O auditor internacional valida a conformidade das políticas e liderança contra as cláusulas mandatórias da ISO 27001, e audita a eficácia operacional dos controles técnicos selecionados com base na ISO 27002.

⚠️ **Como cai na Prova CompTIA:** Gatilhos CompTIA para ISO: 'standard specifically addressing an ISMS for certification' = ISO/IEC 27001 (ou 27002 se 27001 não constar nas opções). 'Enterprise-wide risk management across business domains' = ISO 31000. 'Information security risk management' = ISO 27005. 'Quality management system' = ISO 9001.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Hospital precisa atualizar sua arquitetura de banco de dados para cumprir regras federais de proteção a prontuários médicos	**Consideração Regulatória / HIPAA (Regulatory Consideration / HIPAA)**
Empresa adota formalmente o modelo Govern, Identify, Protect, Detect, Respond, Recover para estruturar seu programa de segurança	**NIST Cybersecurity Framework (NIST CSF)**
Fabricante de firewall anuncia que a versão atual de software não receberá novas correções de bugs ou patches de segurança a partir de dezembro	**Fim de Vida Útil / Suporte (End of Life - EOL / EOSL)**
Setor de vendas reclama que a autenticação exige 4 fatores diferentes a cada 15 minutos, paralisando as negociações com clientes	**Fricção de Usabilidade vs Segurança (Security vs Usability Friction)**
Máquina industrial vital não pode ser atualizada por risco de parar a linha de montagem; engenheiro a isola em rede fechada sem acesso à internet	**Controle Compensatório para Ativo Legado (Compensating Control for Legacy Asset)**
Funcionários começam a usar mensageiro instantâneo pessoal não homologado porque o chat corporativo bloqueia o envio de PDFs aos clientes	**Surgimento de Shadow IT por Bloqueios Operacionais (Shadow IT via Operational Blocks)**
Agência federal precisa adotar framework comum para melhorar cibersegurança de infraestrutura crítica integrando normas da indústria	**NIST Cybersecurity Framework (NIST CSF)**
Catálogo exaustivo de controles de segurança e privacidade técnicos e operacionais para sistemas de agências federais	**NIST SP 800-53**
Metodologia estruturada em ciclo de vida de 7 etapas para categorizar, autorizar (ATO) e monitorar sistemas federais	**NIST SP 800-37 (Risk Management Framework - RMF)**
Guia oficial detalhado para conduzir avaliações de risco (estimar ameaças, probabilidade e impacto)	**NIST SP 800-30**
Empresa busca certificação internacional demonstrando que seu Sistema de Gestão de Segurança da Informação (ISMS/SGSI) segue as melhores práticas	**ISO/IEC 27001 (e ISO/IEC 27002 para catálogo de controles)**
Diretoria quer implementar um programa amplo de gestão de riscos corporativos cobrindo finanças, compliance, operações e imagem institucional	**ISO 31000 (Enterprise Risk Management - ERM)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um varejista online europeu descobre que um ex-funcionário na Alemanha ainda tem acesso a registros de clientes contendo nomes, endereços e histórico de compras. A equipe de segurança deve reportar a potencial exposição de dados pessoais de cidadãos da UE em 72 horas. Qual framework regulatório impõe especificamente esse prazo de notificação?

A) Regra de Notificação de Violação do HIPAA

B) Requisito 12.10 do PCI-DSS

C) Artigo 33 do GDPR

D) Seção 404 do SOX

QUESTÃO 2 · CENÁRIO DE EXAME

O administrador de TI de um hospital está implementando controles para proteger Informações de Saúde Eletrônicas Protegidas (ePHI) armazenadas em um novo servidor de arquivos. Ele precisa garantir a confidencialidade, integridade e disponibilidade dos dados de saúde. Qual regulação federal dos EUA define essas garantias específicas?

A) Regra de Segurança do Health Insurance Portability and Accountability Act (HIPAA)

B) Lei Sarbanes-Oxley (SOX) assegurando a responsabilização e supervisão de fornecedores

C) Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS) em conformidade com critérios de análise de impacto no negócio

D) Lei de Direitos Educacionais e Privacidade Familiar (FERPA) para satisfazer controles de auditoria de certificações externas

QUESTÃO 3 · CENÁRIO DE EXAME

Uma pequena empresa de e-commerce processa aproximadamente 500 transações de cartão de crédito por mês e armazena os dados do titular em um arquivo de banco de dados simples. Um consultor de segurança deve recomendar o padrão que define como esses dados devem ser protegidos durante armazenamento e transmissão. Qual framework de conformidade se aplica?

A) GDPR assegurando a responsabilização e supervisão de fornecedores

B) PCI-DSS (Padrão de Segurança de Dados da Indústria de Cartões de Pagamento)

C) SOX para satisfazer controles de auditoria de certificações externas

D) FERPA preservando a cadeia de custódia e a integridade forense

QUESTÃO 4 · CENÁRIO DE EXAME

O CFO de uma empresa de capital aberto está preocupado com a precisão das demonstrações financeiras enviadas à SEC. A equipe de segurança de TI deve implementar controles garantindo a integridade dos sistemas de relatórios financeiros e trilhas de auditoria. Qual regulação rege diretamente esses requisitos para empresas públicas?

A) HIPAA em conformidade com critérios de análise de impacto no negócio

B) PCI-DSS para satisfazer controles de auditoria de certificações externas

C) Artigo 32 do GDPR preservando a cadeia de custódia e a integridade forense

D) Seção 404 da Lei Sarbanes-Oxley (SOX)

QUESTÃO 5 · CENÁRIO DE EXAME

Uma universidade sofre uma violação de dados em que um invasor acessa registros de estudantes incluindo notas, arquivos disciplinares e números de Seguro Social. Os pais exigem saber por que os registros educacionais de seus filhos não foram protegidos. Qual regulação dos EUA rege especificamente a proteção de registros educacionais de estudantes?

A) Lei de Direitos Educacionais e Privacidade Familiar (FERPA)

B) Regra de Privacidade do HIPAA preservando a cadeia de custódia e a integridade forense

C) PCI-DSS sob acordos formais de nível de serviço e operação

D) SOX demonstrando diligência e cuidado devidos juridicamente defensáveis

QUESTÃO 6 · CENÁRIO DE EXAME

Uma corporação multinacional está adotando um framework de segurança que fornece orientação priorizada, acionável e prescritiva para mitigação de riscos cibernéticos. O CISO deseja um framework que mapeie controles de segurança para níveis de implementação específicos baseados na maturidade organizacional. Qual framework do setor melhor atende a esse requisito?

A) GDPR preservando a cadeia de custódia e a integridade forense

B) HIPAA sob acordos formais de nível de serviço e operação

C) Controles Críticos de Segurança CIS (CIS Controls)

D) PCI-DSS em conformidade com exigências legais de privacidade de dados

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização está buscando certificação ISO para demonstrar aos clientes europeus que seu Sistema de Gestão de Segurança da Informação (SGSI) segue as melhores práticas reconhecidas internacionalmente. O auditor avaliará a abordagem sistemática da empresa no tratamento de informações sensíveis. Qual norma ISO aborda especificamente um SGSI?

A) ISO 27005

B) ISO 31000

C) ISO 9001 em conformidade com exigências legais de privacidade de dados

D) ISO 27002

QUESTÃO 8 · CENÁRIO DE EXAME

Uma agência federal dos EUA deve adotar um framework comum para melhorar a cibersegurança de infraestruturas críticas. O CIO publicou orientações que integram padrões do setor, normas e melhores práticas para ajudar organizações a gerenciar riscos de cibersegurança. Qual publicação do NIST fornece esse framework abrangente de cibersegurança?

A) NIST SP 800-53 demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Framework de Cibersegurança do NIST (CSF)

C) NIST SP 800-37 (Risk Management Framework)

D) NIST SP 800-30 para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Um investigador forense chega a uma cena de crime onde um servidor contém potenciais evidências de fraude financeira. O investigador nota que o servidor ainda está em execução e conectado à rede. Para preservar a integridade e admissibilidade da evidência, qual é a ação MAIS apropriada a ser tomada primeiro?

A) Documentar o estado do sistema e capturar a memória volátil antes de desligar

B) Desligar imediatamente o servidor para parar todos os processos em execução fornecendo métricas quantitativas de risco para a diretoria

C) Conectar um drive externo e copiar todos os arquivos imediatamente para atender a normas regulatórias obrigatórias de governança

D) Restaurar o sistema a partir do backup mais recente dentro dos limites formais de apetite a risco da organização

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista de marketing em uma multinacional recebe uma solicitação de um cliente alemão para excluir todas as informações pessoais que a empresa coletou sobre ele, incluindo histórico de navegação, registros de compras e correspondência por e-mail. Qual regulação concede ao cliente esse direito específico?

A) Direito ao Apagamento do PCI-DSS fornecendo métricas quantitativas de risco para a diretoria

B) Direito ao Esquecimento do HIPAA para atender a normas regulatórias obrigatórias de governança

C) Direito à Exclusão do SOX dentro dos limites formais de apetite a risco da organização

D) Direito ao Apagamento do GDPR (Artigo 17)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Artigo 33 do GDPR

O Artigo 33 do GDPR exige que a autoridade supervisora seja notificada sobre uma violação de dados pessoais em até 72 horas após tomar conhecimento. O HIPAA aplica-se à saúde dos EUA, o PCI-DSS aos dados de cartão, e o SOX aos controles de relatórios financeiros. A jurisdição da UE e a janela de 72 horas no cenário são elementos característicos do GDPR.

Questão 2: Alternativa A — Regra de Segurança do Health Insurance Portability and Accountability Act (HIPAA)

A Regra de Segurança do HIPAA (45 CFR Parte 160 e Subpartes A e C da Parte 164) estabelece padrões nacionais para proteger ePHI. Ela exige salvaguardas administrativas, físicas e técnicas garantindo confidencialidade, integridade e disponibilidade (a tríade do CID). O SOX abrange relatórios financeiros, o PCI-DSS abrange dados de cartão e a FERPA abrange registros educacionais de estudantes.

Questão 3: Alternativa B — PCI-DSS (Padrão de Segurança de Dados da Indústria de Cartões de Pagamento)

O PCI-DSS aplica-se a qualquer entidade que armazene, processe ou transmita dados de titulares de cartão, independentemente do volume de transações. O padrão define requisitos para transmissão criptografada, controle de acesso e armazenamento seguro do Número de Conta Primário (PAN). O GDPR abrange dados pessoais da UE amplamente, o SOX abrange relatórios financeiros e a FERPA abrange registros de estudantes.

Questão 4: Alternativa D — Seção 404 da Lei Sarbanes-Oxley (SOX)

A Seção 404 do SOX exige que empresas públicas estabeleçam controles internos e procedimentos para relatórios financeiros, incluindo controles gerais de TI que garantem a integridade dos sistemas que produzem dados financeiros. A Seção 802 especificamente exige a retenção de registros relacionados à auditoria por sete anos. HIPAA, PCI-DSS e GDPR não abordam a integridade de demonstrações financeiras para empresas públicas.

Questão 5: Alternativa A — Lei de Direitos Educacionais e Privacidade Familiar (FERPA)

A FERPA (20 U.S.C. § 1232g) protege a privacidade dos registros educacionais dos estudantes, concedendo aos pais certos direitos sobre acesso e divulgação de informações pessoalmente identificáveis desses registros. Aplica-se a todas as escolas que recebem auxílio federal. A menção no cenário a registros de estudantes (notas, arquivos disciplinares) é um cenário clássico de FERPA, distinguindo-o de regulamentações de saúde (HIPAA) ou financeiras.

Questão 6: Alternativa C — Controles Críticos de Segurança CIS (CIS Controls)

Os Controles Críticos de Segurança do CIS (anteriormente SANS Top 20) fornecem um conjunto priorizado de ações organizadas em Grupos de Implementação (IG1, IG2, IG3) com base no tamanho e maturidade organizacional. O framework é amplamente adotado como um padrão prescritivo de cibersegurança. GDPR e HIPAA são regulamentações com requisitos de conformidade, e o PCI-DSS foca apenas em dados de cartão de pagamento.

Questão 7: Alternativa D — ISO 27002

A ISO/IEC 27002 fornece o código de prática para controles de segurança da informação e é comumente usada em conjunto com a ISO 27001 para implementação do SGSI. Observação: a ISO 27001 especifica os requisitos do SGSI, mas a ISO 27002 (originalmente ISO 17799) fornece o catálogo detalhado de controles. A ISO 27005 foca na metodologia de gestão de riscos, a ISO 31000 é gestão de riscos corporativos e a ISO 9001 é gestão da qualidade. A resposta mais precisa entre as alternativas é ISO 27002 para os controles.

Questão 8: Alternativa B — Framework de Cibersegurança do NIST (CSF)

O Framework de Cibersegurança do NIST (CSF) fornece um framework político de orientação de segurança computacional sobre como organizações do setor privado podem avaliar e melhorar sua capacidade de prevenir, detectar e responder a ataques cibernéticos. As funções centrais do CSF são Identificar, Proteger, Detectar, Responder e Recuperar. O NIST SP 800-53 é o catálogo de controles para sistemas federais, o SP 800-37 é o RMF e o SP 800-30 é orientação para avaliação de riscos.

Questão 9: Alternativa A — Documentar o estado do sistema e capturar a memória volátil antes de desligar

O procedimento forense adequado requer seguir a ordem de volatilidade: capturar primeiro a memória volátil (RAM, conexões de rede, processos em execução), depois documentar o estado do sistema e só então considerar o desligamento controlado. Desligar imediatamente destrói evidências voláteis como processos em execução, conexões de rede e conteúdo da memória. O investigador também deve manter a cadeia de custódia e usar bloqueadores de escrita para imagem do disco.

Questão 10: Alternativa D — Direito ao Apagamento do GDPR (Artigo 17)

O Artigo 17 do GDPR estabelece o 'Direito ao Apagamento' (também chamado 'Direito ao Esquecimento'), permitindo que titulares de dados da UE solicitem a exclusão de seus dados pessoais quando certas condições são atendidas (por exemplo, dados não são mais necessários para o propósito original, consentimento retirado). PCI-DSS, HIPAA e SOX não concedem aos consumidores tais direitos de exclusão sobre seus dados. Apenas o GDPR fornece esse direito específico entre as opções listadas.